

Security Organization Worksheet

Cybersecurity governance, ownership, escalation, and operating model

Objective. Design a practical security organization model that aligns technical security responsibilities with business ownership, compliance obligations, and incident-response accountability.

1. Security Operating Model

- Executive leadership - sets risk appetite, approves major security investments, and receives material-risk reporting.
- Security leadership - owns the security program, policy direction, risk prioritization, incident governance, metrics, and coordination with legal and compliance.
- SOC / Security Operations - monitors alerts, validates events, triages incidents, documents evidence, escalates confirmed threats, and supports containment.
- IT / Infrastructure - implements hardening, patching, identity, endpoint, network, backup, and recovery controls with security.
- Application / Engineering - owns secure development, vulnerability remediation, secrets management, logging, and production security requirements.
- GRC / Compliance - maintains control mappings, risk registers, audit evidence, policy lifecycle activities, third-party reviews, and remediation tracking.
- Legal / Privacy - advises on breach notification, privacy requirements, regulatory exposure, contracts, and evidence preservation.
- Business owners - classify business impact, own operational risk decisions, approve appropriate access, and complete assigned remediation.

2. Responsibility & Escalation Matrix

Activity	Primary owner	Supporting teams	Escalate when
Security alert triage	SOC Analyst	IT / App owners	Credible malicious activity or business impact
High-severity incident	Incident Lead / Security	SOC, IT, Legal, Business	Material disruption, sensitive data, or executive impact
Vulnerability remediation	System / App Owner	Security, IT	Critical exposure, exploited vulnerability, or missed SLA
Access review	IAM / System Owner	Security, HR, Managers	Excess privilege, orphan account, or policy exception
Compliance evidence	GRC / Control Owner	Security, IT, Legal	Missing evidence, failed control, or audit exception
Risk acceptance	Business Risk Owner	Security, GRC	Residual risk exceeds normal tolerance
Recovery validation	IT / Business Continuity	Security, Business Owner	Recovery target missed or integrity is uncertain

3. Incident Severity & Communication Model

- **Severity 1 - Critical:** Active compromise, major outage, ransomware, material data exposure, or widespread operational impact. Start immediate incident leadership, executive notification, legal/privacy engagement when applicable, and continuous status updates.
- **Severity 2 - High:** Confirmed malicious activity or significant control failure with limited scope. Prioritize rapid containment, system-owner engagement, a documented timeline, and leadership awareness.
- **Severity 3 - Medium:** Suspicious activity requiring investigation, a vulnerability with compensating controls, or a contained policy/control issue. Complete analyst investigation and tracked remediation.
- **Severity 4 - Low:** Informational event, low-risk finding, or request suitable for standard operational queues.

4. Governance Cadence

Cadence	Forum	Purpose	Outputs
Daily	SOC / Operations Review	Review active alerts, incidents, and blockers	Queue priorities, escalations, incident notes
Weekly	Security Operations Review	Review trends, vulnerabilities, and remediation	Action owners, SLA risks, control issues
Monthly	Risk & Compliance Review	Review risk register, exceptions, and audit readiness	Risk decisions, evidence gaps, policy actions
Quarterly	Executive Security Review	Report posture, material risks, and progress	Investment decisions, risk acceptance, priorities

5. Framework Alignment

- **NIST CSF 2.0:** Govern establishes ownership and policy; Identify supports asset and risk awareness; Protect guides safeguards; Detect supports monitoring; Respond structures incident handling; Recover supports restoration and lessons learned.
- **ISO/IEC 27001:** Aligns governance, risk treatment, documented responsibilities, policies, continual improvement, and control ownership with an information security management system.
- **COBIT 2019:** Reinforces enterprise governance, accountability, performance management, and alignment between security activities and business objectives.

6. Analyst Takeaways

- Know who owns the system, the risk, the control, and the remediation before an incident occurs.
- Escalate based on evidence and business impact, not alert volume alone.
- Document decisions, timestamps, evidence, ownership, and next actions so work can survive handoffs and audits.
- Translate technical findings into operational and business consequences so stakeholders can make informed decisions.